Halotrcer report

Target http://127.0.0.1:18089/v1 · 2026-10-20 12:00 UTC · halotrcer test
Tokvera v0.1.0-dev (ok) · Sievant v0.1.0-157-gd8a8bcf (ok)

> tokvera v0.1.0-dev is outside the versions this release supports (>=0.2.0 <0.3.0)

Executive summary

Efficiency grade (Tokvera): A · Provisional scoring
Cost per 1,000 requests: $0.0475 (measured, rates as of 2026-10-20)
At your volume: $95.00 a month (2,000,000 requests/month you gave × measured cost)
Agent security (Sievant): 4 critical, 8 high · deal risk: 12 finding(s)

Top 5 findings, ranked by business impact

1. Hard-coded database URL with password
Sievant SEC001 · security · deal risk · server db · args[2] · critical security finding (Sievant SEC001)
Fix: Move it to the environment or a secret store and reference it (for example ${SERVER_TOKEN}); then rotate it, since it has been on disk.

2. Hard-coded GitHub token
Sievant SEC001 · security · deal risk · server github · env.GITHUB_PERSONAL_ACCESS_TOKEN · critical security finding (Sievant SEC001)
Fix: Move it to the environment or a secret store and reference it (for example ${GITHUB_PERSONAL_ACCESS_TOKEN}); then rotate it, since it has been on disk.

3. Hard-coded Slack token
Sievant SEC001 · security · deal risk · server slack · env.SLACK_BOT_TOKEN · critical security finding (Sievant SEC001)
Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

4. Hard-coded Anthropic API key
Sievant SEC001 · security · deal risk · server remote · headers.Authorization · critical security finding (Sievant SEC001)
Fix: Reference it from the environment and rotate it.

5. Remote server over plain HTTP
Sievant NET001 · security · deal risk · server plain · url · deal risk: a customer security review would flag Sievant NET001 (high)
Fix: Use {masked-url}.

Cost & performance

From Tokvera: http://127.0.0.1:18089/v1 · model tokvera-sim-batched

Efficiency grade: A (97.2 / 100, scoring 0.9.0)

Provisional scoring. The weights and thresholds are provisional: they have not yet been calibrated against real pilot scans and may change before scoring 1.0.0.
Requests: 24 sent, 24 succeeded, 0 failed, in 1.4 s.

Concurrency	Requests	Failed	TTFT p50	TTFT p95	TTFT p99	Duration p95
1	8	0	35.8 ms	36.7 ms	36.7 ms	98.2 ms
2	8	0	36.1 ms	36.9 ms	36.9 ms	98.2 ms
4	8	0	36.3 ms	36.4 ms	36.4 ms	98.5 ms

Cost

$0.0475 per 1,000 requests (estimate), rates as of 2026-10-20, source: halotrcer fixture (synthetic rate, not a real price)
At the 2,000,000 requests a month you gave: $95.00 a month (measured cost × your volume). This is spend, not a saving.

Findings

No Prometheus metrics at /metrics · warn · -5 grade points · effort 0.5 days

no Prometheus exposition answered at /metrics on the target's origin

Queue depth, batch size and cache usage are what explain a latency problem. Without them, a slowdown can be seen but not diagnosed.

Fix: Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Tokvera contacts only the target you specify, plus GitHub when you run update or doctor --check-update, and tokvera.halotrcer.com and GitHub for the plugin's first-run install.
The load used Tokvera's fixed, harmless benchmark prompts. Response text was read for timing and discarded; none is stored in this report.

Agent security

From Sievant: the MCP server configuration of the AI clients on this machine.
claude-desktop · testdata/scan/claude_desktop_config.json · file · 11 server(s), 10 not behind Sievant
custom · testdata/scan/claude.json · file · 3 server(s), 3 not behind Sievant
custom · testdata/scan/cursor-mcp.json · file · 4 server(s), 4 not behind Sievant
custom · testdata/scan/vscode-mcp.jsonc · file · 2 server(s), 2 not behind Sievant
custom · testdata/scan/windsurf-mcp_config.json · file · 1 server(s), 1 not behind Sievant
Findings: 4 critical, 8 high, 7 medium, 0 low, 1 info.

Critical: Hard-coded database URL with password (SEC001) · deal risk

claude-desktop · testdata/scan/claude_desktop_config.json · server db · args[2]

Evidence (masked): post… (29 chars)

Fix: Move it to the environment or a secret store and reference it (for example ${SERVER_TOKEN}); then rotate it, since it has been on disk.

Critical: Hard-coded GitHub token (SEC001) · deal risk

claude-desktop · testdata/scan/claude_desktop_config.json · server github · env.GITHUB_PERSONAL_ACCESS_TOKEN

Evidence (masked): ghp_… (40 chars)

Fix: Move it to the environment or a secret store and reference it (for example ${GITHUB_PERSONAL_ACCESS_TOKEN}); then rotate it, since it has been on disk.

Critical: Hard-coded Slack token (SEC001) · deal risk

custom · testdata/scan/cursor-mcp.json · server slack · env.SLACK_BOT_TOKEN

Evidence (masked): xoxb… (28 chars)

Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

Critical: Hard-coded Anthropic API key (SEC001) · deal risk

custom · testdata/scan/windsurf-mcp_config.json · server remote · headers.Authorization

Evidence (masked): sk-a… (53 chars)

Fix: Reference it from the environment and rotate it.

High: Remote server over plain HTTP (NET001) · deal risk

custom · testdata/scan/claude.json · server plain · url

Evidence (masked): http://mcp.internal.example:8080

Fix: Use {masked-url}.

High: Access to the whole filesystem (PERM001) · deal risk

claude-desktop · testdata/scan/claude_desktop_config.json · server files · args[2]

Evidence (masked): /

Fix: Give the server only the directories it needs, for example the project directory.

High: Literal value in secret-named field X-API-Key (SEC002) · deal risk

custom · testdata/scan/vscode-mcp.jsonc · server api · headers.X-API-Key

Evidence (masked): lite… (21 chars)

Fix: Reference it from the environment (for example ${X_API_KEY}) and rotate it.

High: Credential embedded in the server URL (SEC004) · deal risk

claude-desktop · testdata/scan/claude_desktop_config.json · server remote-bridge · args[2]

Evidence (masked): https://mcp.capability.example/tenant/server/{masked:36}/mcp?user_id={masked:8}

Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that

authenticates with a header referenced from the environment.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server cap-remote · url

Evidence (masked): https://mcp.capability.example/apps/{masked:22}/mcp

Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server notes · url

Evidence (masked): https://mcp.example.com/sse{masked:16}

Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

High: Server fetched from a repository or URL at start (SUP002)

claude-desktop · testdata/scan/claude_desktop_config.json · server git-source · args

Evidence (masked): github:example/mcp-server

Fix: Use a published release pinned to an exact version (or a commit hash).

High: Server launched by a script downloaded at start (SUP002)

claude-desktop · testdata/scan/claude_desktop_config.json · server installer · args

Evidence (masked): -c curl -fsSL https://example.com/install.sh | sh

Fix: Install a pinned release and run it directly.

Medium: Remote server with no credential configured (AUTH001) · deal risk

custom · testdata/scan/claude.json · server remote-noauth · url

Evidence (masked): https://mcp.example.com

Fix: Confirm the server requires authentication (OAuth or a header referenced from the environment).

Medium: Access to the whole home directory (PERM002) · deal risk

claude-desktop · testdata/scan/claude_desktop_config.json · server home · args[2]

Evidence (masked): ~

Fix: Give the server only the directories it needs.

Medium: Server runs with the host network (container) (PERM003)

claude-desktop · testdata/scan/claude_desktop_config.json · server docker · args[3]

Evidence (masked): --network

Fix: Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

Medium: Server runs with all permissions (Deno) (PERM003)

custom · testdata/scan/cursor-mcp.json · server deno · args[1]

Evidence (masked): --allow-all

Fix: Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

Medium: Unpinned server version (SUP001)

claude-desktop · testdata/scan/claude_desktop_config.json · server docker · args

Evidence (masked): example/mcp-server

Fix: Pin the image by digest (image@sha256:…) or at least an exact version tag.

Medium: Unpinned server version (SUP001)

claude-desktop · testdata/scan/claude_desktop_config.json · server github · args

Evidence (masked): @example/github-mcp

Fix: Pin an exact version, for example example/github-mcp@1.2.3 (with its scope), and update it deliberately.

Medium: Server pinned to a moving tag (latest) (SUP001)

claude-desktop · testdata/scan/claude_desktop_config.json · server latest · args

Evidence (masked): example-mcp@latest

Fix: Pin an exact version (name==1.2.3) and update it deliberately.

Info: Launched through Sievant (SVT001)

claude-desktop · testdata/scan/claude_desktop_config.json · server wrapped

Tool descriptions, and the resources and prompts each server offers, were not checked: that needs starting the servers (sievant scan --inspect-tools, which runs them).

30-day fix plan

Week 1: critical exposure and quick fixes

- Hard-coded database URL with password (Sievant SEC001)
  Move it to the environment or a secret store and reference it (for example ${SERVER_TOKEN}); then rotate it, since it has been on disk.
- Hard-coded GitHub token (Sievant SEC001)
  Move it to the environment or a secret store and reference it (for example ${GITHUB_PERSONAL_ACCESS_TOKEN}); then rotate it, since it has been on disk.
- Hard-coded Slack token (Sievant SEC001)
  Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.
- Hard-coded Anthropic API key (Sievant SEC001)
  Reference it from the environment and rotate it.
- Remote server over plain HTTP (Sievant NET001)
  Use {masked-url}.
- Access to the whole filesystem (Sievant PERM001)
  Give the server only the directories it needs, for example the project directory.
- Literal value in secret-named field X-API-Key (Sievant SEC002)
  Reference it from the environment (for example ${X_API_KEY}) and rotate it.
- Credential embedded in the server URL (Sievant SEC004)
  Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
- Credential embedded in the server URL (Sievant SEC004)
  Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
- Credential embedded in the server URL (Sievant SEC004)
  Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
- No Prometheus metrics at /metrics (Tokvera metrics_endpoint)
  Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Week 2: the largest cost and latency failures

Nothing this week.

Week 3: remaining high-severity security findings

- Server fetched from a repository or URL at start (Sievant SUP002)
  Use a published release pinned to an exact version (or a commit hash).
- Server launched by a script downloaded at start (Sievant SUP002)
  Install a pinned release and run it directly.

Week 4: everything else

- Remote server with no credential configured (Sievant AUTH001)
  Confirm the server requires authentication (OAuth or a header referenced from the environment).
- Access to the whole home directory (Sievant PERM002)
  Give the server only the directories it needs.
- Server runs with the host network (container) (Sievant PERM003)
  Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).
- Server runs with all permissions (Deno) (Sievant PERM003)
  Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).
- Unpinned server version (Sievant SUP001)
  Pin the image by digest (image@sha256:…) or at least an exact version tag.
- Unpinned server version (Sievant SUP001)
  Pin an exact version, for example example/github-mcp@1.2.3 (with its scope), and update it deliberately.
- Server pinned to a moving tag (latest) (Sievant SUP001)
  Pin an exact version (name==1.2.3) and update it deliberately.
- Launched through Sievant (Sievant SVT001)

How to read this report

Halotrcer's ranking across the two tools is provisional (scoring version 0.1.0): its tiers are judgement, not calibrated. See docs/scoring.md.

Halotrcer contacts only the target you give it (through Tokvera) and reads only the MCP configuration files Sievant reads, on this machine. It sends no telemetry. Secrets stay masked as each tool masks them; on top of that, Halotrcer drops URL credentials and query strings, hides environment values, shows your home directory as ~ and replaces your user name with <user>.

Want a second pair of eyes? Book the AI Cost & Security Audit: https://www.halotrcer.com/book

Generated by halotrcer test · schema halotrcer.check-report/v1.0.0